



Tammy Buchanan <tammy.buchanan@dataprotection.education>

BILTT: Information Security and Data Retention

1 message

Tammy Buchanan <tammy.buchanan@dataprotection.education>

14 December 2022 at 15:50

To: Paul Panter <paul.panter@biltt.org>, Paula Burgess <paula.burgess@biltt.org>

Cc: Tammy Buchanan <tammy.buchanan@dataprotection.education>

Hi Paul,

Thank you for your time today, it was really good to understand how BILTT works in terms of information security and data retention. Please find below some of the details we discussed (plus good for me to have for future reference):

- You are moving network drives over to SharePoint
- You use Azure (currently hybrid) with multi factor authentication which is always the first thing we would advise for cyber security
- Backups - you have offline and offsite backups in line with the NCSC recommendations
- Broadband - you have a fibre leased line with a backup (which is good for business continuity)
- USB's are banned but there is no physical test for someone using a USB, there are anti-virus tools available that can detect this and separate from other devices such as iPads and cameras
- Wi-Fi - you have a secure network, public and guest (we would always recommend a guest network so that visitors do not have access to network resources)
- Mobile device management - for controlling mobile devices in a secure and managed way, we discussed the possible use of Intune.
- Printers - all PIN coded so printing is only done when a user enters a PIN which reduces the risk of data getting lost
- Trustees/Governors - we discussed Governors using email on their phones and requesting apps. We agreed that logging into Office 365 to access email is the safest way for BILTT for them to access their email. We also discussed the use of SharePoint for sharing governor files rather than emails with attachments being sent around and different versions of files.
- Cyber Attack plan - we discussed a cyber attack plan in terms of making sure that everyone knows what to do if the organisation is attacked, who to report it to, where to make claims and how to recover systems and backups:

- Record what you will do, when, how and by whom if an attack happens - it is easier to react if a plan is already in place
- Record key contact details, login details to key systems and other information you might need if you couldn't access anything in your organisation
- Plan for a range of likely events that can affect your school's data such as ransomware, internet outage or fire
- Keep the plan in a safe, secure, yet accessible place - not on premises.

This leads onto a Business Continuity Plan as the central team in a Trust is a business organisation and so needs to continue running. The best practice area on the Knowledgebank has a Business Continuity template which you might find helpful: <https://dataprotection.education/best-practice-library/documents/information-technology-security/131-dpe-business-continuity-template>

This is a real issue for Trusts especially if systems are shared and are open across all schools because then all the data is only as safe as the weakest link/school. In September of this year a Trust with six schools suffered an attack: <https://techmonitor.ai/technology/cybersecurity/uk-schools-cyberattack-scholars-education-trust>

- Retention - you advised that the data retention for everything in the Trust is 7 years. Please see this link below from the iRMS toolkit which advises (from page 37) what the requirements are for the different file and data types: <https://dataprotection.education/best-practice-library/documents/guides/18-irms-schools-toolkit> this information can also be found in the Data Protection- annual review checklist on the DfE website: <https://www.gov.uk/government/publications/data-protection-toolkit-for-schools>, so given these recommendations would advise reviewing the 7 years that is currently in place.

- I advised that it is possible to set organisation wide retention on both the Sent and Deleted Folders in email, which can be quite short and reduces unnecessary emails which can cause employee SARS to be large.

I also suggested speaking to Dell about purchasing through the HealthTrust Europe framework which they sell through and purchasing devices with Shape The Future which are essentially devices without a Windows license (as you are already covered under your Microsoft agreement you don't need to buy another). Sometimes this is cheaper but not always, but purchasing through the framework should be.

I have copied Paula in as the Cyber Attack Plan, Business Continuity Plan and Retention is something that I can continue to discuss with her at our next meeting.

Have a lovely Christmas break.

Many thanks,

Tammy Buchanan
Data Protection Consultant

BSc(Hons) Computer Science

ITIL 4 Service Management, NCFE Principles of Cyber Security

Direct dial: 07513 821409

Phone: 0800 0862018

<https://dataprotection.education/>



Data Protection Education Ltd. is a limited company registered in England and Wales.

Company No. 10863106

Registered office: 1 Saltmore Farm, New Inn Rd, Hertfordshire, SG7 5EZ